14 — Procédure de gestion des violations de données

English: ../en/14-data-breach-procedure.md

> **MODÈLE — DOCUMENT INTERNE.** À adapter à l'équipe réelle ; délais légaux à confirmer.

Cartouche	
Juridiction	RDC — Code du numérique, Livre III (sécurité, notification)
Hypothèses	H-03, H-05 (autorité compétente), H-15 (délai de 72 heures, source secondaire)
Sources	S01, S16 — voir 00-recherche-juridique.md § 7
Clauses à valider	V-06 (délai et contenu de la notification)
Version	[NUMÉRO] du [DATE]

1. Définition

Violation de données : toute atteinte à la sécurité entraînant, de manière accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation ou l'accès non autorisé à des données personnelles (exemples : base exposée, compte d'administrateur compromis, sauvegarde perdue, envoi à un mauvais destinataire, rançongiciel).

2. Rôles

Rôle	Personne	Suppléant
Responsable de l'incident	[NOM]	[NOM]
Délégué à la protection des données	[NOM]	—
Technique (serveur, base)	[NOM]	[NOM]
Communication clients	[NOM]	[NOM]
Conseil juridique	[CABINET]	—

3. Étapes et délais

Délai (à partir de la détection)	Action
immédiat	consigner l'heure de détection dans le registre des incidents ; prévenir le responsable de l'incident
< 4 h	contenir : couper l'accès compromis, révoquer les sessions (`sessions` révoquées par établissement ou globalement), changer les secrets concernés (`NH_SECRET_KEY` seulement si nécessaire : voir les conséquences dans le guide de configuration), conserver les journaux (`journalctl -u nhill-server`, journal d'audit)
< 24 h	évaluer : données et personnes concernées, établissements touchés, risque pour les personnes ; **informer les établissements clients concernés** (nous sommes leur sous-traitant, modèle 06)
< 72 h **[À VALIDER : V-06]**	**notifier l'autorité de protection des données** pour les traitements dont Nhill est responsable, si la violation présente un risque ; les établissements notifient pour leurs propres traitements, avec notre aide

Délai (à partir de la détection)	Action
sans délai injustifié	informer les personnes concernées si le risque est élevé (langage simple : ce qui s'est passé, conséquences, mesures, conseils, contact)
< 30 jours	analyse des causes, correctifs, test, compte rendu ; mise à jour de l'audit de sécurité

4. Contenu de la notification à l'autorité

Nature de la violation ; catégories et nombre approximatif de personnes et d'enregistrements ; coordonnées du délégué ; conséquences probables ; mesures prises ou envisagées. Si tout n'est pas connu, notifier ce qui l'est et compléter ensuite.

Autorité : [NOM, ADRESSE, E-MAIL, FORMULAIRE — ARPTC à titre provisoire ou ARPTIC, à confirmer, H-05].

5. Registre des incidents

Chaque incident, même non notifié, est consigné :

Date de détection	Description	Données / personnes	Risque	Mesures	Notifié à l'autorité (date)	Personnes informées (date)	Clôture

6. Exercice

Simuler un incident [une fois par an] (par exemple : fuite d'une sauvegarde) et mesurer les délais réels.